

Benchmark - Developing Contingency Strategies for Information System

Grand Canyon University

ITT-430 IT Security Driven Systems Administration

Professor Timothy Montgomery

Liela Pressley

February 2, 2025

LITE CONTINGENCY PLAN



Business Impact Analysis (BIA)

Pike's Peak Health Care conducted a Business Impact Analysis to determine the business processes and the criticality of recovering those business processes in addition to identifying and prioritizing resources. PPHC's first priority is providing healthcare to the community and ensuring that our staff are equipped with the proper tools, resources and information to administer the care. Conducting the BIA is beneficial as it allows for PPHC to identify critical functions and processes that need to be recovered quickly and first during an outage or attack. In doing so, our leadership will be able to properly prioritize tasks for the business, identify all risks including third-party risks, and calculate downtime costs. Additionally, BIA allows leadership to identify legal, regulatory and contract compliance requirements. The BIA allows for PPHC to properly implement and prioritize backup and restoration systems to the top priority systems and ensure that data privacy protocols are enforced. As well as enhance current business processes to incorporate security by designs that address current risks and threats.

Threats against Assets (Highest to Lowest)	Impact of Loss	Measures to Recover from Threat
Outdated Systems Open Door to Security threats from lack of Updates/Patches	Security threats can open systems to be exploited with zero-day vulnerabilities and known vulnerabilities alike. This can result in data breaches, system failures, compliance risks and data loss which can lead to PPHC data being compromised, modified, or inaccessible by an unauthorized user which can lead to patient care not	Within the next two years, PPHC is going to implement new systems and ensure that updates and patches are implemented regularly to ensure that all known vulnerabilities are addressed and patched as they are being released. If the threat is acted upon, PPHC will refer to the backup and recovery plan to ensure

	being administered properly due to inaccurate records to records not being accessible. Business processes can be slowed down or unable to operate properly.	that patient data is secured and remains with integrity.
Medical Devices Exploited to gain access to PPHC's network or remotely accessible	Medical devices that have vulnerabilities that are exploited can allow attackers to gain access to the PPHC network which can lead to access to ePHI, network devices and even control network accessibility. This can cause network traffic blockages, inaccessibility to ePHI, data breaches, network devices being breached, etc. If the medical devices are accessed it can result in high consequences of failure which can lead to patient care being compromised.	PPHC will implement a program to help staff members ensure necessary medical devices are patched in alignment with compliance requirements within a rotation. This allows for medical devices to always be available yet be patched in groups and reduce the potential for attack. Additionally if the threat occurs, PPHC will continue communication with its vendors and contracts to ensure that recovery measures are acted upon asap.
Phishing/Social Engineering attacks lead to malware/network compromise	Successful phishing or social engineered attacks can result in malware being downloaded on PPHC systems, compromising the network and allowing unauthorized users to gain access to different user accounts, patient data, and other health care systems.	Recovery will involved PPHC securing all PPHC accounts, resetting all passwords, monitoring all financial statements for anomalies, running antimalware and antivirus software to ensure it was installed, and implementing a forensic analysis to ensure no damage occurred.
Ransomware attacks locks patient data, hospital system lockdown, restrict equipment operation	Ransomware attacks can prevent patient care as it prevents access to data, networks, equipment operations and more.	The recovery will ensure that ransomware is neutralized and blocked so that it does not further infect data and travel through the network. Next PPHC will ensure that all trigger files are removed, disconnect vulnerable or infected devices, and restore

		file systems.
DDoS floods hospital's website with fake requests, control network devices, disrupt online servers, accessibility to resources/scheduling, etc.	DDoS can deny access to patients or employees trying to access the website to manage appointments, message doctors, gain access to prescriptions, etc.	PPHC has a recovery plan in place in case a DDoS attack occurs such as restart firewalls, communicate with Internet service providers, recover applications, review logs to understand the origin of the attack.

Incident Response Plan (IRP)

Overview: PPHC senior management developed an IRP to implement an incident response policy and plan in alignment with computer security incident response team members. The IRP will cover immediate, real-time strategies and goals, senior management's approval, how the incident response team communicates methods, incident response metrics, maturity roadmap and fitting the program to the entire organization. The IRP will be activated when the organization detects an incident that impacts it from minor to major.

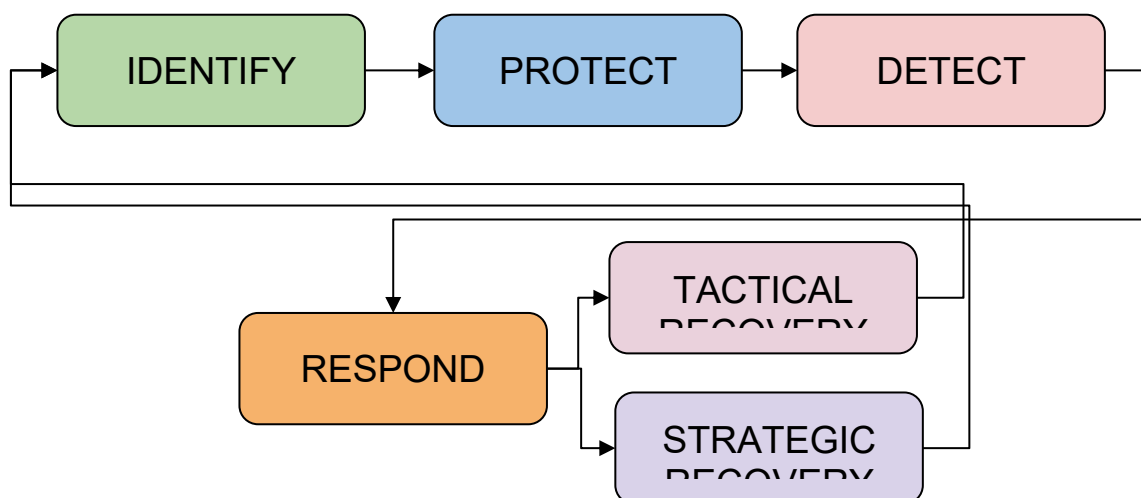
Roles and Responsibilities

- Security Analysts will focus on reviewing security threats within the network specifically handling alerts, responding to threats, and building security strategies focusing on containment, remediation and recovery.
- Threat Hunters focus on supporting tier 3 analysts by assessing information by looking through the network, endpoints and data to identify/isolate threats and collaborate with previous shifts to brief on ongoing incidents/events.
- SOC managers oversee and support the analysts by directing SOC operations, providing training, hiring new team members, syncing analysts with DevOps and strategizing security policies.
- Security engineers design secure information systems and document the application security protocols.
- Incident response director focuses on coordinating and directing response efforts while overseeing the response team. This role addresses the demands of the incidents, assigning analysts to different information streams for a team structure that can be adaptable to the needs of the organization.
- CISO is the chief information security officer focused on strategic decisions to best proactively secure the organization from industry threats regarding budgets, business objectives, and plans.

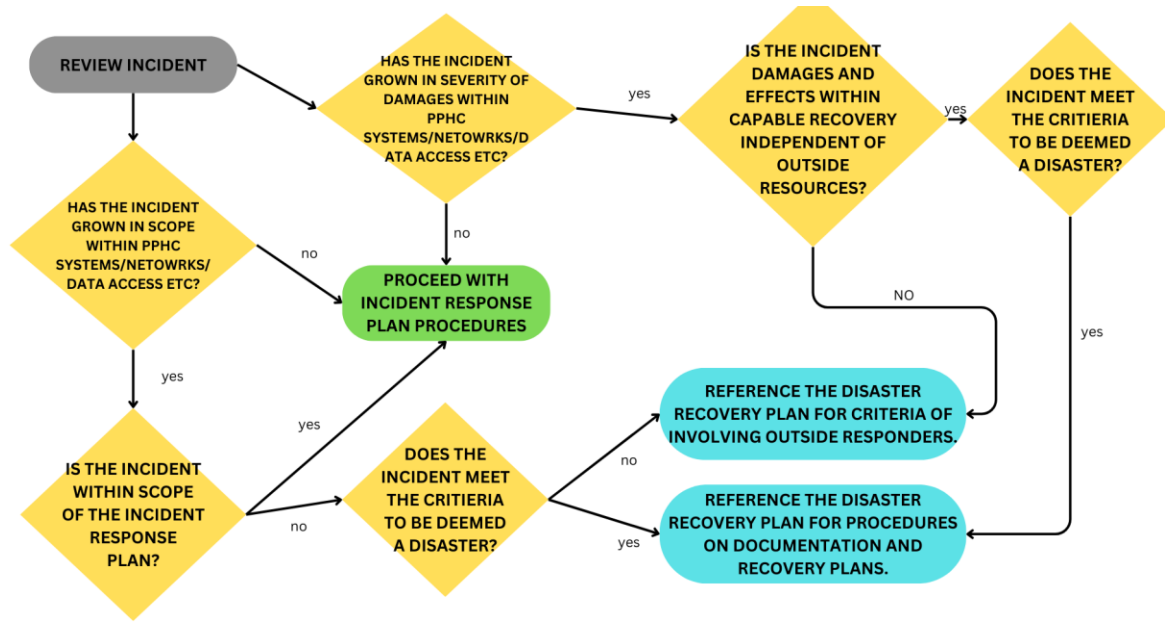
Activities that all departments of PPHC need to ensure are implemented and enforced for proper mitigation of possible/real time threats include conducting regular cybersecurity risk

assessments, developing risk-handling procedures for identification, regularly training team members, information sharing guidelines, installing patches and updates regularly, encrypting and backup up data, monitor vendors, comply with industry regulations, and refining the IRP regularly based on industry best practices.

PPHC references the NIST SP 800-61 IR phase plan for a foundational guideline of workflow when handling an incident. The 6 main stages of incident handling include: Identify, Protect, Detect, Respond, Tactical Recovery and Strategic Recovery. Identify focuses on ensuring that our risk management and governance is properly identified, Protect focuses on implementing effective security controls, Detect relates to detecting cyber events as they occur (IDS, IPS), Respond focuses on responding to the anomaly/cyber event and to remediate the root cause, Tactical and Strategic Recovery focuses on replacing things as they were prior to the incident.



If the incident escalates in scope or severity the IP plan is limited in its ability to aid the situation, but it can provide criteria and insight into where PPHC leadership will deem an incident a disaster or transfer the incident to an outside authority (law enforcement/public response).



Incident Response teams will reference the *IRP Escalation Matrix* to determine the severity of the incident, the proper resolution and the expected response/resolution time.

Incident Severity	Description	Resolution	Expected Response Time	Expected Resolution Time
New Feature Request	When a user requests a new feature or improvement	Evaluate the purpose, outline steps to integrate the feature after management approves.	Provide response within a week	Resolution will vary depending on the process and management review/approval.
Low	Minor incidents that have minimal impact on operations and users	Simple corrective actions or workarounds to resolve the issue.	Must be acknowledged within 4 hours.	Must be resolved within 1 business day.
Normal	Standard incident that affects a few users but doesn't disrupt core operations/activit	Provide procedures to address and resolve the incident timely	Must respond within 2 hours.	Must resolve within 4 hours.

	ies			
High	Serious incidents that affect many users or critical functionalities.	Take strategic actions to mitigate the incident and restore normal operations.	Respond immediately; no later than 1 hr.	Resolve as soon as possible, no later than 1 hr.
Critical	Critical incidents that need immediate action to prevent major disruptions or recover from disruptions.	Take immediate interventions and resolve the incident and minimize negative impact.	Respond instantly; within 15 minutes.	Resolve immediately; within 30 mins.

Additionally, PPHC wants to ensure that every staff member is not alone when identifying and responding to an incident. Below is the Official PPHC Contact Alert Roster which provides contact information for personnel that are to be notified in the event of an incident or disaster to occur.

1. Incident Response Manager

- **Name:** Alex Simpson
- **Role:** Incident Response Team Lead
- **Responsibilities:** addresses the demands of the incidents, assigning analysts to different information streams for a team structure that can be adaptable to the needs of the organization.
- **Phone:** +1 (123) 555-4567
- **Email:** alex.simpson@pphc.com

2. SOC Manager/Lead

- **Name:** Isabella Staffman
- **Role:** SOC Manager/Leader
- **Responsibilities:** Oversees the SOC team, monitors suspicious activity, investigates incoming threat and risk alerts, provides technical analysis on security incidents
- **Phone:** +1 (123) 555-6934
- **Email:** isabella.staffman@pphc.com

3.IT and Network Support Lead

- **Name:** Jared Sophmyer
- **Role:**IT and Network Support Lead
- **Responsibilities:** Provides technical support for systems, network and service maintenance and restoration.
- **Phone:** +1 (123) 555-9687
- **Email:** jared.sophmyer@pphc.com

4.Chief Information Security Officer (CISO)

- **Name:** Norman Ableman
- **Role:**CISO
- **Responsibilities:** Provides executive level leadership, strategic planning, provides significant incident response decisions, communicates with fellow board members and manages resources.
- **Phone:** +1 (123) 555-8521
- **Email:** norman.ableman@pphc.com

5. Human Resources (HR)

- **Name:** Alyssa Raybond
- **Role:**HR Manager
- **Responsibilities:** Handles internal and external employee related tasks such as insider threats, employee communications, workforce management when an incident occurs.
- **Phone:** +1 (123) 555-7410
- **Email:** jared.sophmyer@pphc.com

6. Data Backup and Recovery Specialist

- **Name:**Brad Mino
- **Role:**Data Backup and Recovery Specialist
- **Responsibilities:** Ensures that data backup systems are maintained and that recovery processes are efficient,accurate and effective regularly.
- **Phone:** +1 (123) 555-7410
- **Email:** jared.sophmyer@pphc.com

Disaster Recovery Plan (DRP)

Develop a DRP that contains the following in alignment with the company:

Purpose

PPHC invests in the health and safety of its patients and employees which motivated the development of a DRP which provides detailed direction and guidance on how the organization plans to prepare proactively for a disaster and the best ways to recover from it regardless if it's man-made or natural.

Scope

PPHC's disaster plan covers any incident that is beyond scope or severity within the matrix provided in the IRP from malware that evades and infects PPHC systems to natural events such as flooding, fires, earthquakes, etc. Due to the various locations of PPHC along with the different services and equipment that are being provided at each location, the DRP will vary based on location and will be adjusted accordingly by the DRP leadership at each location.

Roles and responsibilities

As PPHC seeks to be as unified and consistent in our planning most of the team that collaborated for the information recovery plan will provide insight and guidance for the DRP.

CISO is the chief information security officer focused on strategic decisions to best proactively secure the organization from industry threats regarding budgets, business objectives, and plans.

Disaster Recovery Coordinator oversees the DRP, ensures the development, testing and implementation is flexible and successful while providing guidance/monitoring to the DRP planning team.

Data Backup and Recovery Specialist focuses on ensuring that data backup systems are maintained, data is accurate, confidential and available, and ensuring that backups are occurring regularly.

HR Manager navigates and handles any internal and external employee needs from employee communications to workforce management.

Resource requirements

PPHC prioritizes being proactive in preparing for any disaster that may occur and therefore will ensure that all necessary funding and resources are dedicated to data backups, insurance and restoration services. The backups that PPHC is invested in include cloud based backups such as Azure Storage, having prepped Disaster Recovery Sites where our medical personnel and patients can relocate to for medical care, and having back up communication systems separate from the main service provider.

Training requirements

All medical staff are trained in providing medical care in case of a natural disaster but PPHC will also mandate non-medically trained staff to become certified in CPR training. In addition, all staff members must complete regular training regarding malware, phishing/social

engineering tactics, emergency contact/communication information, evacuation procedures, and necessary tasks to be completed in the event of a disaster.

Explanation of an exercise to test the DRP in a predetermined scenario

PPHC will perform regular exercises through verbal walk throughs with medical staff prior to their shift as reperforming these tests during patient care would not be effective. But through reinforced videos and reinforced briefings and once a year physical drills an exercise will provide personnel with proper information. To prepare for a natural disaster such as a tornado, PPHC will provide a video training along with using a 3-D model to show the necessary physical procedures of where to move patients, equipment and have medical staff stay. Additionally it will walk non-medical staff through the necessary technical procedures and what the potential effects could be such as damage to the information systems or the access of the information systems across different locations or building wings. And ways that this can be mitigated which is through insurance and backup/restoration systems. Each location will have a list of the specific role/responsibility of each team member in case a disaster arises.

Maintenance schedules

Each manager who is included in the CP is aware of the maintenance schedules that must be adhered to for the proactive security and wellness of information systems and physical security of PPHC.

Backups and Recovery systems must be updated and maintained daily to ensure that all patient data is secured, accurate and backed up properly.

All systems must be updated and have the most up to date security patches to reduce vulnerabilities being exploited daily or weekly (depending on the compliance requirement).

All medical equipment must have their vendors update equipment on a weekly basis.

Risk assessments must be performed monthly and updated in alignment with the latest updates to the regulatory requirements.

Testing and drills must be conducted monthly.

Communication updates must be provided as needed.

Training will be distributed weekly and with deadlines varying depending on the severity of the topic.

Business Continuity Plan (BCP)

Usage Strategy

There are 3 key usage strategies that PPHC considered for the Business Continuity Plan; a hot site is when a secondary site is fully configured, duplicated computer facility with all services, workstations, communication links, etc. A warm site is when the same services and options are available from the hot site but a lot of the software applications are not included/installed, whereas a cold site only has the absolute basic services and facilities with no computer hardware provided with communication services provided after personnel moves in. PPHC understands that all personnel will require work spaces as soon as possible to provide patient care 24/7, hence opting for a hot usage site and for patients who require more intense care; they would be transported to nearby care facilities. Since PPHC requires 24/7 capability and real-time resources, this is the best strategy for the company, its patients and its employees.

Recovery

If a threat is acted upon or a disaster occurs, PPHC will refer to the backup and recovery plan to ensure that patient and company data is secured and remains with integrity from cloud-based recovery programs.

If IT equipment or systems are affected, PPHC has servers and applications backed up on hot usage sites where they can be restored.

PPHC will continue communication with its vendors and contracts to ensure that recovery measures are acted upon asap.

Recovery will involve PPHC securing all PPHC accounts, resetting all passwords, monitoring all financial statements for anomalies, running antimalware and antivirus software to ensure it was installed, and implementing a forensic analysis to ensure no damage occurred.

PPHC has a recovery procedure in place in case a DDoS attack occurs such as restart firewalls, communicate with Internet service providers, recover applications, review logs to understand the origin of the attack.

Reestablish Operations

In the event of a disaster where a PPHC location is destroyed, PPHC would relocate all high priority business operations to the usage hot site where all necessary technical and medical equipment would be ready to use for patient care. Some low-priority services will be restricted to specific days or virtually if possible to allow medical staff to provide effective care within the space and time given. Since all PPHC data is backed up on cloud based servers all information should be available to use as soon as possible. PPHC will look into continual insurance policies for additional financial resources as it seeks to restore the original building and IT infrastructure while employees utilize the alternative space. Then create a realistic but high priority timeline with restoration milestones varying from renovations, technological updates and restorations, etc. Once the restoration is complete, each service/department will be able to slowly transition back to the original space. Ideally, PPHC would work with government organizations and donations to provide additional financial support to renovate on a quick timeline and restore the building within 2 years.

Readiness

Each role has different responsibilities if an incident or disaster occurs which will determine specific training exercises and reviews that need to be made accordingly. As a whole, each employee must complete mandatory training for physical safety, patient safety, and account/data privacy while also being well informed on the BCP processes relevant to their role. The readiness training will be executed via training, in person drills, 3-D model reenactments, during briefings prior to shifts starting, and through email reminders.

References

- Alder, S. (2024, March). *63% of Known Exploited Vulnerabilities Can be Found in Hospital Networks*. The HIPAA Journal. <https://www.hipaajournal.com/63pc-known-exploited-vulnerabilities-hospital-networks/>
- Atumu, M. (2024, November). *Cybersecurity Threat mitigation: prevention and protection*. Liquid Web. <https://www.liquidweb.com/blog/mitigate-security-risk/>
- CISA. (2021). Incident Response Plan (IRP) basics. In *CISA | DEFEND TODAY, SECURE TOMORROW* [Report].
https://www.cisa.gov/sites/default/files/publications/Incident-Response-Plan-Basics_508c.pdf
- Columbia University in the City of New York. (2013, October). *Business Continuity and Disaster Recovery Policy*. <https://universitypolicies.columbia.edu/>.
<https://universitypolicies.columbia.edu/content/business-continuity-and-disaster-recovery-policy>
- How to Recover from a Ransomware Attack*. (n.d.). Rubrik.
<https://www.rubrik.com/insights/how-to-recover-from-ransomware>
- Netalit. (2024, November 4). *Cybersecurity Team roles and responsibilities*. Check Point Software. <https://www.checkpoint.com/cyber-hub/cyber-security/cybersecurity-team-roles-and-responsibilities/>
- Okeke, F. (2023, September 11). *How to recover from a DDOS attack in 4 steps*. Enterprise Networking Planet.
<https://www.enterprisenetworkingplanet.com/security/how-to-recover-from-a-ddos-attack/#:~:text=into%20security%20lemonade->

,What%20to%20do%20after%20a%20DDoS%20attack,your%20systems%20against%20future%20threats.

Patterson, C. (2024, July 17). Free escalation templates: all formats. *Smartsheet*.

<https://www.smartsheet.com/content/escalation-matrix-templates>

Whitman, M., & Mattord, H. (2021). *3P-EBK: PRINCIPLES of information security*. Cengage.